

WEB APPLICATION SECURITY TESTING

Minor Project Report

Submitted by

Name: Katlapudi Mahammad Ismail
Email: mdismailshaik99@gmail.com
Mobile: 9390554573
Date: 6 July 2026

1. Executive Summary

This project demonstrates security testing of Damn Vulnerable Web Application (DVWA) v1.10 on Kali Linux. The objective was to identify, exploit, and recommend mitigations for OWASP Top 10 vulnerabilities. Testing was performed in a local laboratory environment for educational purposes only. Three major vulnerabilities were confirmed: SQL Injection, Reflected Cross-Site Scripting (XSS), and OS Command Injection. Tools used include Kali Linux 2026, DVWA v1.10, Burp Suite Community Edition, and Nikto Scanner.

2. Finding 1: SQL Injection

Severity: High (CVSS 8.1)

Location: DVWA → SQL Injection → Low Security Level.

Description: The application concatenates user input directly into SQL queries without sanitization. An attacker can inject SQL statements to extract unauthorized database information or bypass authentication.

Steps: Log in with default credentials, set Security Level to Low, open SQL Injection page, enter payload ' OR '1'='1 --', submit, and observe all user records displayed.

Impact: Database disclosure, authentication bypass, data modification or deletion.

Remediation: Use prepared statements, validate input, enforce least privilege, and return generic error messages.

3. Finding 2: Reflected XSS

Severity: Medium (CVSS 6.1).

Description: User input is reflected back without HTML encoding, allowing JavaScript execution in the victim's browser.

Steps: Open XSS Reflected page, enter <script>alert('XSS-Proof')</script>, submit, and observe the alert dialog.

Impact: Session theft, phishing, and keystroke capture.

Remediation: Use htmlspecialchars(), implement CSP, validate input, and enable HttpOnly and Secure cookie flags.

4. Finding 3: OS Command Injection

Severity: High (CVSS 7.8).

Description: The application passes user input directly to the ping command without validation, allowing command chaining.

Steps: Enter 127.0.0.1 && whoami and observe the server user displayed.

Impact: Arbitrary command execution, sensitive file access, possible server compromise.

Remediation: Use escapeshellcmd(), escapeshellarg(), whitelist validation, avoid system commands where possible, and run services with least privilege.

5. Security Recommendations

Use prepared statements, output encoding, command escaping, input validation, least privilege, current software versions, regular security testing, code reviews, and verify fixes using DVWA Impossible security level.

6. Conclusion

This project demonstrates that inadequate input validation can lead to serious security

vulnerabilities. The DVWA Impossible security level successfully mitigates these issues, highlighting the importance of secure coding practices and regular penetration testing.

Appendix A

Demo Video: Add your Google Drive or YouTube Unlisted link.

Appendix B

OS: Kali Linux 2026

Target: DVWA v1.10 (Localhost)

Browser: Firefox

Note: Insert the three screenshots in the appropriate sections before final submission.